

WebShield Security Report

Report ID: WS-8-20260629
Generated: 2026-06-29 02:03:55 UTC
Target: https://aldane-portfilo.onrender.com

Executive Summary

Score	Risk	Findings	Groups	Pages	Duration
0/100	CRITICAL	89	11	14	33s

The website has critical security issues that require immediate attention. There are severe vulnerabilities that could lead to complete system compromise.

Critical	High	Medium	Low	Info
0	2	45	42	0

Priority Triage

Priority	Severity	Finding	Count	First URL
1	HIGH	URL-Derived Data Written to HTML Sink	1	https://aldane-portfilo.onrender.com/static/js/main.js
2	HIGH	Cookie 'session' Missing Secure Flag	1	https://aldane-portfilo.onrender.com
3	MEDIUM	Cookie 'session' Missing SameSite Attribute	1	https://aldane-portfilo.onrender.com
4	MEDIUM	Session Cookie 'session' Has No Expiration	1	https://aldane-portfilo.onrender.com
5	MEDIUM	Missing Content-Security-Policy Header	14	https://aldane-portfilo.onrender.com
6	MEDIUM	Missing Strict-Transport-Security Header	14	https://aldane-portfilo.onrender.com
7	MEDIUM	Missing X-Frame-Options Header	14	https://aldane-portfilo.onrender.com
8	MEDIUM	Form Missing CSRF Protection	1	https://aldane-portfilo.onrender.com/contact

Category Overview

Category	Instances	Groups	Highest
Cookies	3	3	HIGH
Client Code	1	1	HIGH
Security Headers	84	6	MEDIUM
Vulnerabilities	1	1	MEDIUM

Grouped Findings

1. [HIGH] URL-Derived Data Written to HTML Sink

1 finding(s), 1 affected URL(s)

Description: JavaScript appears to route URL-derived data into an HTML sink such as innerHTML, outerHTML, insertAdjacentHTML, or document.write. This is a common DOM XSS pattern.

Evidence: Line 236: main.innerHTML = nextMain.innerHTML;

Recommendation: Use textContent for plain text, sanitize trusted markup with a maintained sanitizer, and avoid rendering location/search/hash data as HTML.

Affected URLs:

<https://aldane-portfilo.onrender.com/static/js/main.js>

2. [HIGH] Cookie 'session' Missing Secure Flag

1 finding(s), 1 affected URL(s)

Description: The cookie 'session' does not have the Secure flag set, making it vulnerable to interception over HTTP connections.

Evidence: Cookie 'session' is missing the Secure flag

Recommendation: Set the Secure flag on all cookies to ensure they are only sent over HTTPS.

Affected URLs:

<https://aldane-portfilo.onrender.com>

3. [MEDIUM] Cookie 'session' Missing SameSite Attribute

1 finding(s), 1 affected URL(s)

Description: The cookie 'session' does not have the SameSite attribute set, making it vulnerable to CSRF attacks.

Evidence: Cookie 'session' is missing SameSite attribute

Recommendation: Set SameSite attribute to Lax or Strict for session cookies.

Affected URLs:

<https://aldane-portfilo.onrender.com>

4. [MEDIUM] Session Cookie 'session' Has No Expiration

1 finding(s), 1 affected URL(s)

Description: The session cookie 'session' does not have an expiration set, making it a session cookie that may persist indefinitely.

Evidence: Cookie 'session' has no max-age or expires attribute

Recommendation: Set appropriate expiration for session cookies to limit session lifetime.

Affected URLs:

<https://aldane-portfilo.onrender.com>

5. [MEDIUM] Missing Content-Security-Policy Header

14 finding(s), 14 affected URL(s)

Description: The Content-Security-Policy header is missing on this page. CSP helps prevent XSS and data injection attacks.

Evidence: Header 'Content-Security-Policy' not found in response headers.

Recommendation: Implement a Content-Security-Policy header to restrict resources.

Affected URLs:

<https://aldane-portfilo.onrender.com>

<https://aldane-portfilo.onrender.com/about>

<https://aldane-portfilo.onrender.com/admin>

<https://aldane-portfilo.onrender.com/blog>

<https://aldane-portfilo.onrender.com/blog/building-admin-dashboards-flask>

<https://aldane-portfilo.onrender.com/blog/feed.xml>

+8 more affected URL(s)

6. [MEDIUM] Missing Strict-Transport-Security Header

14 finding(s), 14 affected URL(s)

Description: The Strict-Transport-Security header is missing on this page. HSTS enforces HTTPS connections.

Evidence: Header 'Strict-Transport-Security' not found in response headers.

Recommendation: Add HSTS header to enforce HTTPS and prevent SSL stripping.

Affected URLs:

<https://aldane-portfilo.onrender.com>
<https://aldane-portfilo.onrender.com/about>
<https://aldane-portfilo.onrender.com/admin>
<https://aldane-portfilo.onrender.com/blog>
<https://aldane-portfilo.onrender.com/blog/building-admin-dashboards-flask>
<https://aldane-portfilo.onrender.com/blog/feed.xml>
+8 more affected URL(s)

7. [MEDIUM] Missing X-Frame-Options Header

14 finding(s), 14 affected URL(s)

Description: The X-Frame-Options header is missing on this page. X-Frame-Options prevents clickjacking attacks.

Evidence: Header 'X-Frame-Options' not found in response headers.

Recommendation: Set X-Frame-Options to DENY or SAMEORIGIN.

Affected URLs:

<https://aldane-portfilo.onrender.com>
<https://aldane-portfilo.onrender.com/about>
<https://aldane-portfilo.onrender.com/admin>
<https://aldane-portfilo.onrender.com/blog>
<https://aldane-portfilo.onrender.com/blog/building-admin-dashboards-flask>
<https://aldane-portfilo.onrender.com/blog/feed.xml>
+8 more affected URL(s)

8. [MEDIUM] Form Missing CSRF Protection

1 finding(s), 1 affected URL(s)

Description: A form with 5 inputs is missing CSRF protection tokens.

Evidence: Form action: <https://api.web3forms.com/submit>, Method: POST

Recommendation: Implement CSRF tokens for all state-changing forms.

Affected URLs:

<https://aldane-portfilo.onrender.com/contact>

9. [LOW] Missing Permissions-Policy Header

14 finding(s), 14 affected URL(s)

Description: The Permissions-Policy header is missing on this page. Controls which browser features can be used.

Evidence: Header 'Permissions-Policy' not found in response headers.

Recommendation: Set Permissions-Policy to restrict unnecessary features.

Affected URLs:

<https://aldane-portfilo.onrender.com>
<https://aldane-portfilo.onrender.com/about>
<https://aldane-portfilo.onrender.com/admin>
<https://aldane-portfilo.onrender.com/blog>
<https://aldane-portfilo.onrender.com/blog/building-admin-dashboards-flask>
<https://aldane-portfilo.onrender.com/blog/feed.xml>
+8 more affected URL(s)

10. [LOW] Missing Referrer-Policy Header

14 finding(s), 14 affected URL(s)

Description: The Referrer-Policy header is missing on this page. Controls how much referrer information is sent.

Evidence: Header 'Referrer-Policy' not found in response headers.

Recommendation: Set Referrer-Policy to strict-origin-when-cross-origin or similar.

Affected URLs:

https://aldane-portfilo.onrender.com
https://aldane-portfilo.onrender.com/about
https://aldane-portfilo.onrender.com/admin
https://aldane-portfilo.onrender.com/blog
https://aldane-portfilo.onrender.com/blog/building-admin-dashboards-flask
https://aldane-portfilo.onrender.com/blog/feed.xml
+8 more affected URL(s)

11. [LOW] Missing X-Content-Type-Options Header

14 finding(s), 14 affected URL(s)

Description: The X-Content-Type-Options header is missing on this page. Prevents MIME type sniffing attacks.

Evidence: Header 'X-Content-Type-Options' not found in response headers.

Recommendation: Set X-Content-Type-Options to nosniff.

Affected URLs:

https://aldane-portfilo.onrender.com
https://aldane-portfilo.onrender.com/about
https://aldane-portfilo.onrender.com/admin
https://aldane-portfilo.onrender.com/blog
https://aldane-portfilo.onrender.com/blog/building-admin-dashboards-flask
https://aldane-portfilo.onrender.com/blog/feed.xml
+8 more affected URL(s)

Generated by WebShield Scanner v1.0.0

For educational and authorized security testing only.